

AI Incident Response Plan & After-Action Template

Sentinel Nexus - AI Governance / Incident Response

RW

June 2026

Contents

Purpose	2
What is an AI incident	2
Minimum incident record (GV-4.3-002)	2
Detection sources	2
Response workflow	3
After-Action Review template	3
Continuous improvement	4

Purpose

Per NIST AI 600-1 **GV-1.5-002**, **MG-4.3** (incident communication/tracking), and **GV-4.3-002** (minimum incident criteria), this plan defines what constitutes an *AI incident* for Sentinel Nexus, how it is detected, triaged, communicated, and reviewed, and provides a standard after-action template. It complements the SP 800-53 IR family and the platform’s own (operational) incident-handling mission.

What is an AI incident

An AI incident is any event where the development, use, or malfunction of a Nexus AI/ML component contributes to harm or unacceptable risk, including:

- **Mis-containment** — autonomous (or HitL-approved) action against a benign asset, or failure to contain a confirmed threat (a miss).
- **Confabulation reaching action** — a verdict acted upon whose cited evidence did not exist (grounding-control bypass).
- **Bias / disparity** — the fairness audit flags systematic over/under-containment of a subgroup.
- **Model-collapse / homogenization** — the immunity-memory monitor flags over-concentration; or a deployed model regresses on the eval suite post-swap.
- **Security event on an AI component** — prompt-injection success, model-weight tampering, canary leak, training-data poisoning, or membership-inference exposure.
- **Supply-chain event** — a frontier provider’s silent model change alters verdict behavior; a dependency or weight integrity failure.

Minimum incident record (GV-4.3-002)

Field	Notes
Incident ID	auto-generated
Title / type	from the categories above
Reporter / system source	operator, automated control, or AI Actor
Date detected / date occurred	UTC
Affected component(s)	per AI System Inventory
Description & detection path	which control surfaced it
Impact(s) & stakeholders	assets, operators, data subjects
Verdict/model versions in play	for traceability

Detection sources

Most AI incidents are surfaced by an existing control, not manual discovery: the **canary tripwire** (prompt-leak), the **review-board grounding** override, the **bias/homogenization audit** (NC-1), the **calibration ledger** drift (NC-2), the **automation-bias / over-reliance metric** (NC-8, operators rubber-stamping wrong AI calls), the **deploy-gate eval** failure, the **cognitive-fault DLQ**, and operator dispositions.

Response workflow

1. **Detect & record** — the control logs to its ledger/DLQ; create the incident record. The **tamper-evident verdict-lineage chain** (NC-10) provides a non-repudiable record of the decisions in play, and the **active-learning capture** (NC-9) preserves the failing verdict as a hard example for post-incident model improvement.
2. **Contain** — for a model issue, **re-pin the last-known-good registry version** (planned WS-A) or disable the affected backend; the platform's fail-safe defaults mean detection degrades to monitoring rather than mis-acting.
3. **Eradicate / remediate** — fix the control gap (add a test that reproduces it — the standing rule: every incident yields a regression test), retune/retrain if a model issue, rotate secrets if a security event.
4. **Recover** — restore service from the hardened baseline; verify via the eval gate.
5. **Communicate** — notify the system owner and, where legally required (e.g. breach-reporting obligations), the relevant authority. Internal-only by default.
6. **After-action review** — within 5 business days, complete the template below.

After-Action Review template

AI INCIDENT AFTER-ACTION REVIEW

Incident ID: _____ Severity: [Low|Med|High|Critical]

Date occurred / detected / closed: ____ / ____ / ____

Component(s): _____ (AI System Inventory ref)

Detection source: _____ (which control)

Summary (what happened):

...

Root cause:

...

Impact (assets / operators / data subjects):

...

Immediate containment taken:

...

Corrective actions (each with an owner + due date):

- [] Regression test added that reproduces the failure: _____
- [] Control gap fixed: _____
- [] Model retuned / re-pinned (if applicable): _____
- [] Tracker / SSP / POA&M updated: _____

Lessons learned / preventive measures:

...

Reported to (internal/external) and when:

...

Reviewed by: _____ Date: _____

Continuous improvement

After-action findings feed the NIST AI control tracker, the SSP POA&M, and — for detection misses — the MLOps corpus (a miss becomes a frozen replay case and a training example), closing the learn-from-incident loop.